

Analyse d'incident de sécurité : La Petite Pâtisserie

Maël - BTS SIO

5 décembre 2025

1 Identification de l'attaque

a. Type d'attaque

Il s'agit d'une attaque par **rançongiciel** (ransomware).

b. Indices

- **Demande de rançon** : Une fenêtre explicite réclame de l'argent .
- **Fichiers illisibles** : Les données sont chiffrées et inaccessibles .
- **Dysfonctionnement** : Apparition de fenêtres étranges sur les postes .

2 Analyse des causes

Voici 5 failles identifiées ayant permis l'attaque :

1. **Mots de passe faibles** : L'usage de « patisserie2024 » facilite les attaques par force brute .
2. **Absence de segmentation** : La box grand public met tout le monde sur le même réseau. Une fois un poste touché, le serveur est directement accessible .
3. **Protection insuffisante** : Windows Defender seul (sans gestion centralisée) est souvent insuffisant contre les menaces avancées actuelles .
4. **Erreur humaine** : L'attaque a probablement démarré par l'ouverture d'un email piégé, ce qui indique un manque de sensibilisation.
5. **Absence de sauvegardes hors ligne** : Si les sauvegardes étaient connectées, elles ont probablement été chiffrées aussi, aggravant l'impact .

3 Mesures d'urgence

5 actions immédiates pour contenir l'incident :

1. **Déconnecter le réseau** : Débrancher la box et les switchs pour couper le lien avec les pirates .
2. **Isoler les machines** : Éteindre ou débrancher les postes infectés pour stopper la propagation .

3. **Protéger les sauvegardes** : Vérifier et isoler physiquement les disques de sauvegarde restants .
4. **Avertir la direction** : Informer le responsable pour la prise de décision (plainte, communication) .
5. **Ne pas éteindre le serveur (si possible)** : Pour permettre une analyse ultérieure (forensic), sauf si le chiffrement est encore en cours.

4 Mesures de prévention

8 mesures pour sécuriser l'avenir :

- Politique de mots de passe complexes et changés régulièrement .
- Sauvegardes régulières avec une copie déconnectée (règle 3-2-1) .
- Installation d'un antivirus professionnel managé .
- Mises à jour automatiques des systèmes et logiciels .
- Mise en place d'un pare-feu matériel dédié .
- Segmentation du réseau (VLAN) pour séparer le serveur des PC .
- Sensibilisation des utilisateurs aux risques (emails, web) .
- Restriction des droits (comptes utilisateurs standards, pas administrateurs).

Livrable : Rapport d'incident

Date : 5 décembre 2025

Objet : Rapport d'intervention – Incident Ransomware

1. Description de l'incident

Le réseau de la TPE a été frappé par un rançongiciel. L'attaque a rendu les fichiers du serveur et des postes illisibles (chiffrement). Une rançon est demandée pour récupérer la clé de déchiffrement. L'activité est bloquée.

2. Chronologie probable

L'infection a débuté sur un poste client (pièce jointe malveillante ou site web). Profitant de mots de passe faibles (« admin123 ») et d'un réseau plat, le virus s'est propagé latéralement jusqu'au contrôleur de domaine pour chiffrer les partages réseaux.

3. Diagnostic

L'attaque a réussi à cause de trois facteurs majeurs :

- Faiblesse des mots de passe.
- Absence de cloisonnement réseau (serveur exposé).
- Manque de protection antivirus proactive.

4. Recommandations finales

Ne pas payer la rançon. Il faut reconstruire le réseau : formater les machines infectées et restaurer les données depuis une sauvegarde saine et isolée. Avant la remise en service, il est impératif de changer tous les mots de passe et d'installer un pare-feu professionnel.